

Password Best Practices -- Guided Notes ANSWER KEY

Unit tp-6.13 | CompTIA Network+ N10-009 Obj. FC0-U71 6.3 | N10-008 FC0-U71 6.3

For instructor use / distribute after students complete the notes.

Question 1

A strong password should be: at least _____ characters long, contain a mix of _____, _____, _____, and _____, and not include obvious personal information like _____, _____, or pet names. Length is the single most important factor -- a 16-character passphrase beats a 10-character complex password in brute force resistance.

Answer: 12 (or more); uppercase letters; lowercase letters; numbers; symbols; names; birthdays.

Question 2

Password _____ means using the same password on multiple sites. It is extremely dangerous because if any one site is breached and your password is exposed, attackers use _____ stuffing attacks to automatically try that password on banking, email, and other accounts. The fix is to use a unique password for _____ account.

Answer: Reuse; credential; every.

Question 3

A password _____ stores all your passwords in an encrypted vault, protected by a single strong _____ password. It can generate and autofill _____, unique passwords for every site. Examples include Bitwarden, 1Password, and LastPass. The browser saves them for _____ of use. This is the recommended solution to the reuse problem.

Answer: Manager; master; random (strong); convenience.

Question 4

Passwords should never be _____ insecurely (written on sticky notes, sent in plain text email, stored in an unencrypted text file). Never share passwords via _____ or messaging apps. If you must write a master password down as a backup, store it in a physically _____ location (safe, locked drawer -- not a monitor sticky note).

Answer: Stored; email; secure.

Question 5

Default passwords on devices (routers, printers, IP cameras) must be _____ immediately on setup. Many devices ship with the same default credentials (like admin/admin or admin/password) that are _____ documented online. Attackers scan for devices with _____ credentials as an automated first step. Failure to change defaults is one of the most common _____ vulnerabilities in home and small business networks.

Answer: Changed; publicly; default; exploited.

Question 6

Password _____ policies require users to change passwords on a regular schedule (e.g., every 90 days). NIST now recommends _____ periodic rotation unless there is evidence of compromise, because forced rotation leads to _____ password choices (e.g., Password1, Password2). Instead, NIST recommends checking passwords against known _____ lists at creation.

Answer: Rotation (expiration); against; predictable; breached (compromised).

Question 7

Passwords in databases must be stored as _____ not plaintext. A _____ function converts the password to a fixed-length digest. A random value called a _____ is added before hashing to ensure two users with the same password have different stored hashes, defeating _____ table attacks.

Answer: Hashes; hash; salt; rainbow.

Question 8 -- Real World Application

REAL WORLD: A student uses the same password ('Gopackers88!') for their school email, Instagram, a gaming forum, and their bank. The gaming forum is breached and their email/password is posted publicly. Within 24 hours, their Instagram is taken over and their bank issues a fraud alert. Explain step by step how the attacker moved from a gaming forum breach to a bank account attempt.

Answer: Step 1 -- Breach acquisition: the gaming forum database is stolen and cracked. The student's email and password hash 'Gopackers88!' is in the breach dump. The hash is cracked (or the site stored passwords in plaintext). The attacker now has: email = student@gmail.com, password = Gopackers88!. Step 2 -- Credential stuffing: the attacker runs an automated tool that takes the stolen email/password pair and tries it against hundreds of popular sites (Instagram, Facebook, Twitter, Amazon, PayPal, major banks) in rapid succession. This is credential stuffing -- the attack relies on password reuse. Step 3 -- Instagram takeover: login succeeds on Instagram. The attacker immediately changes the recovery email and phone number, locking the student out. Step 4 -- Bank attempt: the bank's fraud system flags the login attempt from an unrecognized device or IP and issues an alert, preventing the takeover. Fix: use a password manager to generate a unique random password for every account. Even if the gaming forum is breached, the attacker gains nothing usable elsewhere.